

GDPR compliance report

Generated: 2026-05-02 22:19:07

Halted (P1): False

Overall score: 32%

Critical / Warning / Info: 16 / 21 / 4

Documents

- ../data/testing_files/md_files_post_gdpr/test4_zoho.md

Chapter scores

Chapter	Score
Ch.2 – Principles	36%
Ch.3 – Rights of data subjects	48%
Ch.4 – Controller & processor	22%
Ch.5 – Transfers to third countries	0%
Ch.8 – Remedies, liability & penalties	100%
Ch.9 – Specific processing situations	0%

Top urgent gaps

- Art. 5 (Principles relating to processing): The policy does not explicitly address the principle of data accuracy, including provisions for ensuring data is up-to-date and rectifying inaccurate data.
- Art. 6 (Lawfulness of processing): The policy mentions collecting information for 'legitimate purpose' without specifying the lawful basis under Article 6(1) for this processing. While 'legitimate interest' is mentioned, it's not explicitly stated as the basis for all processing activities. For instance, when signing up for an account, the lawful basis for collecting name, contact number, email, etc., is not clearly defined. Similarly, processing of payment information, testimonials, website interactions, product usage, federated authentication, and referral program data lacks a clearly stated lawful basis.
- Art. 7 (Conditions for consent): The policy does not explicitly state how consent requests are presented in a clearly distinguishable manner from other matters.

Scorecard

Art.	Chapter	Title	P	Score	Severity	Status
5	Ch.2 – Principles	Principles relating to processing	p2	28	warning	partial
6	Ch.2 – Principles	Lawfulness of processing	p2	52	warning	partial
7	Ch.2 – Principles	Conditions for consent	p2	20	warning	partial
8	Ch.2 – Principles	Child's consent	p3	70	warning	present (unverified)
9	Ch.2 – Principles	Special category data	p2	44	warning	partial
10	Ch.2 – Principles	Criminal convictions data	p3	0	critical	missing
11	Ch.2 – Principles	Processing without identification	p2	36	warning	partial
12	Ch.3 – Rights of data su	Transparency & modalities	p2	44	warning	partial
13	Ch.3 – Rights of data su	Info collected from data subject	p2	20	warning	partial
14	Ch.3 – Rights of data su	Info not obtained from data subject	p2	44	warning	partial
15	Ch.3 – Rights of data su	Right of access	p2	44	warning	partial
16	Ch.3 – Rights of data su	Right to rectification	p2	100	info	pass
17	Ch.3 – Rights of data su	Right to erasure	p2	36	warning	partial
18	Ch.3 – Rights of data su	Right to restriction	p2	100	info	pass
19	Ch.3 – Rights of data su	Notification on rectification/erasure	p3	0	critical	missing
20	Ch.3 – Rights of data su	Right to data portability	p2	52	warning	partial
21	Ch.3 – Rights of data su	Right to object	p2	44	warning	partial
22	Ch.3 – Rights of data su	Automated decision-making	p2	44	warning	partial
24	Ch.4 – Controller & proc	Responsibility of the controller	p2	36	warning	partial
25	Ch.4 – Controller & proc	Privacy by design and default	p3	0	critical	missing
26	Ch.4 – Controller & proc	Joint controllers	p3	70	warning	present (unverified)
27	Ch.4 – Controller & proc	Representatives (non-EU)	p3	0	critical	missing
28	Ch.4 – Controller & proc	Processor / DPA	p2	20	warning	partial
29	Ch.4 – Controller & proc	Processing under authority	p2	0	critical	fail
30	Ch.4 – Controller & proc	Records of processing (ROPA)	p2	20	warning	partial
32	Ch.4 – Controller & proc	Security of processing	p3	0	critical	missing
33	Ch.4 – Controller & proc	Breach notification to SA	p3	0	critical	missing
34	Ch.4 – Controller & proc	Breach communication to data subject	p3	0	critical	missing
35	Ch.4 – Controller & proc	DPIA	p3	0	critical	missing
37	Ch.4 – Controller & proc	DPO designation	p2	100	info	pass
38	Ch.4 – Controller & proc	DPO position	p3	70	warning	present (unverified)
39	Ch.4 – Controller & proc	DPO tasks	p2	28	warning	partial
40	Ch.4 – Controller & proc	Codes of conduct	p3	0	critical	missing
42	Ch.4 – Controller & proc	Certification	p3	0	critical	missing
44	Ch.5 – Transfers to thir	General principle for transfers	p2	0	critical	fail
45	Ch.5 – Transfers to thir	Adequacy decision transfers	p2	0	critical	fail
46	Ch.5 – Transfers to thir	Transfers with safeguards	p3	0	critical	missing
47	Ch.5 – Transfers to thir	Binding corporate rules	p3	0	critical	missing
77	Ch.8 – Remedies, liabili	Right to lodge a complaint	p2	100	info	pass
85	Ch.9 – Specific process	Freedom of expression	p4	—	warning	triggered (HIL)
88	Ch.9 – Specific process	Employment context	p2	0	critical	fail

Scope (Art.2/3) + pipeline summary (raw JSON)

```

{
  "scope": {
    "applies": "yes",
    "reasons": [
      "The policy describes the collection and processing of personal data such as name, contact number, email address, company name, and country. This aligns with the material scope of GDPR which applies to the processing of personal data.",
      "The policy mentions that information is collected when a user signs up for an account to access services. If the company has an 'establishment in the Union', GDPR applies to the processing of personal data of users in the Union, regardless of where the processing takes place.",
      "Alternatively, even if the company is not established in the Union, GDPR applies if the processing activities involve offering goods or services to data subjects in the Union or monitoring their behavior within the Union."
    ],
    "evidence": [
      "We collect information about you only if we need the information for some legitimate purpose. Zoho will have information about you only if (a) you have provided the information yourself, (b) Zoho has automatically collected the information, or (c) Zoho has obtained the information from a third party.",
      "When you sign up for an account to access one or more of our services, we ask for information like your name, contact number, email address, company name and country to complete the account signup process."
    ],
    "hil_required": false
  },
  "pipeline_summary": {
    "overall_score_pct": 50,
    "p2_score": 0.5,
    "p2_findings_total": 25,
    "p3_findings_total": 15,
    "p4_triggered_total": 1,
    "p4_articles_not_triggered": 5,
    "findings_total": 41,
    "hil_queue_total": 16
  },
  "computed_scoring": {
    "overall_score_pct": 32,
    "chapter_scores": {
      "Ch.2 - Principles": 36,
      "Ch.3 - Rights of data subjects": 48,
      "Ch.4 - Controller & processor": 22,
      "Ch.5 - Transfers to third countries": 0,
      "Ch.8 - Remedies, liability & penalties": 100,
      "Ch.9 - Specific processing situations": 0
    },
    "severity_counts": {
      "critical": 16,
      "warning": 21,
      "info": 4
    }
  }
}

```

Appendix — finding detail

Art. 5 — Principles relating to processing

Priority: p2 Chapter: Ch.2 – Principles

Severity: warning Status: partial

Score: 28/100

Risk: medium

Gaps

- The policy does not explicitly address the principle of data accuracy, including provisions for ensuring data is up-to-date and rectifying inaccurate data.
- The policy does not explicitly address the principle of storage limitation, including provisions for determining retention periods and secure erasure or anonymization.
- The policy does not explicitly address the principle of integrity and confidentiality, including measures for protecting data against unauthorized or unlawful processing, accidental loss, destruction, or damage.
- The policy does not explicitly address the principle of accountability, including how the organization will demonstrate compliance with the other principles.

Evidence

- The policy states that personal data is collected only if needed for a legitimate purpose (Article 5(1)(b) - purpose limitation).
- The policy describes various scenarios for data collection (account signup, event registration, purchases, testimonials, website visits, product usage, federated authentication, referrals) which indirectly relates to the purpose of collection (Article 5(1)(b) - purpose limitation).
- The policy mentions that certain optional information provided during account signup is not required for the core signup process, suggesting some level of data minimization (Article 5(1)(c) - data minimisation).
- The policy mentions that credit card information is not stored, and payment information is stored in an encrypted format by Payment Gateway Service Providers, which relates to security measures (Article 5(1)(f) - integrity and confidentiality, and potentially Article 5(1)(e) - storage limitation).
- The policy states that first-party cookies are used and third-party cookies are not used on their websites, which can be related to transparency and control over data processing (Article 5(1)(a) - transparency).
- The policy mentions using federated authentication services (LinkedIn, Microsoft, Google) which implies a reliance on third-party systems for identity verification and data sharing, touching on data processing by third parties (Article 5(1)(a) - transparency, and potentially Article 5(1)(f) - integrity and confidentiality).

Notes

The policy addresses lawfulness, fairness, transparency, and purpose limitation to a reasonable extent.

However, it lacks explicit detail on accuracy, storage limitation, integrity and confidentiality, and accountability, which are key principles under Article 5.

```
{
  "article_number": 5,
  "article_title": "Principles relating to processing",
  "chapter": "Ch.2 – Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly address the principle of data accuracy, including provisions for ensuring data is up-to-date and rectifying inaccurate data.",
    "The policy does not explicitly address the principle of storage limitation, including provisions for determining retention periods and secure erasure or anonymization.",
    "The policy does not explicitly address the principle of integrity and confidentiality, including measures for protecting data against unauthorized or unlawful processing, accidental loss, destruction, or damage.",
    "The policy does not explicitly address the principle of accountability, including how the organization will demonstrate compliance with the other principles."
  ],
  "evidence": [
    "The policy states that personal data is collected only if needed for a legitimate purpose ( Article 5(1)(b) - purpose limitation).",
    "The policy describes various scenarios for data collection (account signup, event registration, purchases, testimonials, website visits, product usage, federated authentication, referrals) which indirectly relates to the purpose of collection (Article 5(1)(b) - purpose limitation).",
```

```

    "The policy mentions that certain optional information provided during account signup is not required for the core signup process, suggesting some level of data minimization (Article 5(1)(c) - data minimisation).",
    "The policy mentions that credit card information is not stored, and payment information is stored in an encrypted format by Payment Gateway Service Providers, which relates to security measures (Article 5(1)(f) - integrity and confidentiality, and potentially Article 5(1)(e) - storage limitation).",
    "The policy states that first-party cookies are used and third-party cookies are not used on their websites, which can be related to transparency and control over data processing (Article 5(1)(a) - transparency).",
    "The policy mentions using federated authentication services (LinkedIn, Microsoft, Google) which implies a reliance on third-party systems for identity verification and data sharing, touching on data processing by third parties (Article 5(1)(a) - transparency, and potentially Article 5(1)(f) - integrity and confidentiality).",
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy addresses lawfulness, fairness, transparency, and purpose limitation to a reasonable extent. However, it lacks explicit detail on accuracy, storage limitation, integrity and confidentiality, and accountability, which are key principles under Article 5.",
  "article_material_used": "text"
}

```

Art. 6 — Lawfulness of processing

Priority: p2 **Chapter:** Ch.2 – Principles

Severity: warning **Status:** partial

Score: 52/100

Risk: high

Gaps:

- The policy mentions collecting information for 'legitimate purpose' without specifying the lawful basis under Article 6(1) for this processing. While 'legitimate interest' is mentioned, it's not explicitly stated as the basis for all processing activities. For instance, when signing up for an account, the lawful basis for collecting name, contact number, email, etc., is not clearly defined. Similarly, processing of payment information, testimonials, website interactions, product usage, federated authentication, and referral program data lacks a clearly stated lawful basis.

Evidence:

- The policy states: 'We collect information about you only if we need the information for some legitimate purpose.'
- When signing up for an account, information like name, contact number, email address, company name and country is collected.
- Information submitted during event registration, newsletter subscription, form submissions, contests, surveys, or customer support requests is collected.
- When purchasing, name, contact, and payment information are collected.
- Testimonials may include name and other personal information.
- Interactions via email, telephone, and chat are recorded and analyzed.
- Website visits collect information like IP address, browser type, language preference, etc.
- Cookies, beacons, tags, scripts are used to identify users, track navigation, gather demographic information, and for targeted engagement.

Notes:

The policy generally refers to 'legitimate purpose' and 'legitimate interest' but fails to explicitly link each processing activity to a specific lawful basis as required by Article 6(1) of the GDPR. For many activities, the lawful basis remains unclear.

```

{
  "article_number": 6,
  "article_title": "Lawfulness of processing",
  "chapter": "Ch.2 – Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy mentions collecting information for 'legitimate purpose' without specifying the lawful basis under Article 6(1) for this processing. While 'legitimate interest' is mentioned, it's not explicitly stated as the basis for all processing activities. For instance, when signing up for an account, the lawful basis for collecting name, contact number, email, etc., is not clearly defined. Similarly, processing of payment information, testimonials, website interactions, product usage, federated authentication, and referral program data lacks a

```

```

clearly stated lawful basis."
  ],
  "evidence": [
    "The policy states: 'We collect information about you only if we need the information for some legitimate purpose.'",
    "When signing up for an account, information like name, contact number, email address, company name and country is collected.",
    "Information submitted during event registration, newsletter subscription, form submissions, contests, surveys, or customer support requests is collected.",
    "When purchasing, name, contact, and payment information are collected.",
    "Testimonials may include name and other personal information.",
    "Interactions via email, telephone, and chat are recorded and analyzed.",
    "Website visits collect information like IP address, browser type, language preference, etc."
  ],
  "Cookies, beacons, tags, scripts are used to identify users, track navigation, gather demographic information, and for targeted engagement.",
  "Information about product, service, and mobile application usage is collected.",
  "Federated authentication services (LinkedIn, Microsoft, Google) are used for login.",
  "Referral programs may involve collecting personal information provided by others."
],
"risk": "high",
"needs_human_review": false,
"notes": "The policy generally refers to 'legitimate purpose' and 'legitimate interest' but fails to explicitly link each processing activity to a specific lawful basis as required by Article 6(1) of the GDPR. For many activities, the lawful basis remains unclear.",
"article_material_used": "text"
}

```

Art. 7 — Conditions for consent

Priority: p2 **Chapter:** Ch.2 – Principles

Severity: warning **Status:** partial

Score: 20/100

Risk: medium

Gaps

- The policy does not explicitly state how consent requests are presented in a clearly distinguishable manner from other matters.
- The policy does not provide explicit details on how to ensure consent is specific and unambiguous.
- While the policy mentions the right to withdraw consent and that it's as easy to withdraw as to give consent, it lacks specific details on the mechanism for withdrawal.
- The policy does not explicitly address the conditionality of consent for necessary versus non-necessary processing for a contract or service.
- The policy does not explicitly state that the data subject is informed about the right to withdraw consent **prior** to giving consent.

Evidence

- Policy chunk [c7 7000-8200] states: 'Where we rely on your consent as the legal basis, you have the right to withdraw your consent at any time, but this will not affect any processing that has already taken place.'
- Policy chunk [c7 7000-8200] states: 'You may opt out of receiving newsletters and other non-essential messages by using the 'unsubscribe' function included in all such messages.'
- Policy chunk [c7 7000-8200] states: 'You can disable browser cookies before visiting our websites. However, if you do so, you may not be able to use certain features of the websites properly.'
- Policy chunk [c7 7000-8200] states: 'You can choose not to provide optional profile information such as your photo. You can also delete or change your optional profile information. You can always choose not to fill in non-mandatory fields when you submit any form linked to our websites.'

Notes

The policy mentions the right to withdraw consent and provides an opt-out mechanism for newsletters, indicating some level of compliance. However, it lacks specific details regarding the conditions for freely given, specific, informed, and unambiguous consent, and clear procedures for withdrawal as required by Article 7. The policy does not detail how consent is distinguished from other matters, how it's ensured to be specific and unambiguous, nor does it explicitly state the information provided to the data subject **before** they give consent regarding their right to withdraw. It also does not address the conditionality of consent for performance of a contract.

```

{
  "article_number": 7,

```

```

"article_title": "Conditions for consent",
"chapter": "Ch.2 - Principles",
"priority": "p2",
"status": "partial",
"gaps": [
  "The policy does not explicitly state how consent requests are presented in a clearly distinguishable manner from other matters.",
  "The policy does not provide explicit details on how to ensure consent is specific and unambiguous.",
  "While the policy mentions the right to withdraw consent and that it's as easy to withdraw as to give consent, it lacks specific details on the mechanism for withdrawal.",
  "The policy does not explicitly address the conditionality of consent for necessary versus non-necessary processing for a contract or service.",
  "The policy does not explicitly state that the data subject is informed about the right to withdraw consent *prior* to giving consent."
],
"evidence": [
  "Policy chunk [c7 7000-8200] states: 'Where we rely on your consent as the legal basis, you have the right to withdraw your consent at any time, but this will not affect any processing that has already taken place.'",
  "Policy chunk [c7 7000-8200] states: 'You may opt out of receiving newsletters and other non-essential messages by using the 'unsubscribe' function included in all such messages.'",
  "Policy chunk [c7 7000-8200] states: 'You can disable browser cookies before visiting our websites. However, if you do so, you may not be able to use certain features of the websites properly.'",
  "Policy chunk [c7 7000-8200] states: 'You can choose not to provide optional profile information such as your photo. You can also delete or change your optional profile information. You can always choose not to fill in non-mandatory fields when you submit any form linked to our websites.'"
],
"risk": "medium",
"needs_human_review": false,
"notes": "The policy mentions the right to withdraw consent and provides an opt-out mechanism for newsletters, indicating some level of compliance. However, it lacks specific details regarding the conditions for freely given, specific, informed, and unambiguous consent, and clear procedures for withdrawal as required by Article 7. The policy does not detail how consent is distinguished from other matters, how it's ensured to be specific and unambiguous, nor does it explicitly state the information provided to the data subject *before* they give consent regarding their right to withdraw. It also does not address the conditionality of consent for performance of a contract.",
"article_material_used": "text"
}

```

Art. 8 — Child's consent

Priority: p3 **Chapter:** Ch.2 – Principles
Severity: warning **Status:** present (unverified)
Score: 70/100
Notes

The policy explicitly states that the products and services are not directed at individuals under 16 and that Zoho does not knowingly collect personal information from children under 16. It also outlines the procedure for handling such information if it is discovered.

```

{
  "article_number": 8,
  "article_title": "Child's consent",
  "chapter": "Ch.2 - Principles",
  "priority": "p3",
  "policy_present": true,
  "implementation_unverified": true,
  "needs_human_review": true,
  "evidence": "Our products and services are not directed to individuals under 16. Zoho does not knowingly collect personal information from children who are under 16 years of age. If we become aware that a child under 16 has provided us with personal information, we will take steps to delete such information. If you believe that a child under 16 years has provided personal information to us, please write to privacy@zohocorp.com with the details, and we will take the necessary steps to delete the information we hold about that child.",
  "notes": "The policy explicitly states that the products and services are not directed at individuals under 16 and that Zoho does not knowingly collect personal information from children under 16. It also outlines the procedure for handling such information if it is discovered.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 9 — Special category data

Priority: p2 Chapter: Ch.2 – Principles

Severity: warning Status: partial

Score: 44/100

Risk: medium

Gaps

- The policy mentions that it may rely on explicit consent for processing sensitive data, but it does not specify the mechanism for obtaining or managing this explicit consent in accordance with Article 9(2)(a) of the GDPR. Additionally, while the policy refers to providing information about legitimate interests (Article 9(2)(d)), it does not detail the specific safeguards or conditions under which such processing would be permissible, nor does it explicitly state when it might rely on other derogations under Article 9(2) (e.g., vital interests, legal claims, public interest, health purposes) or the specific conditions and safeguards required for each.
- While the policy touches upon data sharing with third parties (Article 9(2)(a) and Article 9(2)(b)), it does not explicitly state whether such sharing would involve special category data, and if so, what safeguards or legal bases would be applied under Article 9.

Evidence

• RELEVANT POLICY CHUNKS: [c7 7000-8200] - 'Where we rely on your consent as the legal basis, you have the right to withdraw your consent at any time, but this will not affect any processing that has already taken place. : Where we rely on legitimate interests as the legal basis and those legitimate interests are not specified above, we will clearly explain to you what those legitimate interests are at the time that we collect your information.'

• RELEVANT POLICY CHUNKS: [c8 8000-9200] - 'We may need to share your personal information and aggregated or de-identified information with third-party service providers that we engage... These service providers are authorized to use your personal information only as necessary to provide these services to us.'

Notes

The policy acknowledges the potential need for explicit consent and reliance on legitimate interests for data processing. However, it lacks specific details on how explicit consent for special category data is obtained and managed, and how legitimate interests are applied under Article 9, including necessary safeguards. It also doesn't clarify safeguards for sharing special category data.

```
{
  "article_number": 9,
  "article_title": "Special category data",
  "chapter": "Ch.2 – Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy mentions that it may rely on explicit consent for processing sensitive data, but it does not specify the mechanism for obtaining or managing this explicit consent in accordance with Article 9(2)(a) of the GDPR. Additionally, while the policy refers to providing information about legitimate interests (Article 9(2)(d)), it does not detail the specific safeguards or conditions under which such processing would be permissible, nor does it explicitly state when it might rely on other derogations under Article 9(2) (e.g., vital interests, legal claims, public interest, health purposes) or the specific conditions and safeguards required for each.",
    "While the policy touches upon data sharing with third parties (Article 9(2)(a) and Article 9(2)(b)), it does not explicitly state whether such sharing would involve special category data, and if so, what safeguards or legal bases would be applied under Article 9."
  ],
  "evidence": [
    "RELEVANT POLICY CHUNKS: [c7 7000-8200] - 'Where we rely on your consent as the legal basis, you have the right to withdraw your consent at any time, but this will not affect any processing that has already taken place. : Where we rely on legitimate interests as the legal basis and those legitimate interests are not specified above, we will clearly explain to you what those legitimate interests are at the time that we collect your information.'",
    "RELEVANT POLICY CHUNKS: [c8 8000-9200] - 'We may need to share your personal information and aggregated or de-identified information with third-party service providers that we engage... These service providers are authorized to use your personal information only as necessary to provide these services to us.'"
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy acknowledges the potential need for explicit consent and reliance on legitimate interests for data processing. However, it lacks specific details on how explicit consent for special category data is obtained and managed, and how legitimate interests are applied under Article 9, including necessary safeguards. It also doesn't clarify safeguards for sharing special category data.",
  "article_material_used": "text"
}
```


Art. 10 — Criminal convictions data

Priority: p3 Chapter: Ch.2 – Principles
Severity: critical Status: missing
Score: 0/100

```
{
  "article_number": 10,
  "article_title": "Criminal convictions data",
  "chapter": "Ch.2 – Principles",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": null,
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 11 — Processing without identification

Priority: p2 Chapter: Ch.2 – Principles
Severity: warning Status: partial
Score: 36/100
Risk: medium
Gaps

- The policy does not explicitly state that the controller shall inform the data subject if it is not in a position to identify them, as required by Article 11(2).
- The policy does not mention the conditions under which Articles 15-20 would still apply, even if the data subject cannot be identified, as per Article 11(2).
- The policy does not clearly link anonymisation/pseudonymisation claims to data minimisation principles elsewhere in the policy, as guided by the agent.

Evidence

- Article 11(1) states that if purposes do not require identification, the controller is not obliged to maintain, acquire, or process additional information to identify the data subject.
- Article 11(2) states that if the controller is unable to identify the data subject, they should inform them if possible, and Articles 15-20 do not apply unless the data subject provides identifying information.
- Article 4(5) defines pseudonymisation, which is relevant to processing without direct identification.

Notes

The policy addresses the core concept of Article 11 by allowing processing without identification when not necessary. However, it lacks specific details on informing data subjects when identification is not possible and the exceptions to data subject rights in such scenarios. The agent's guidance on linking anonymisation/pseudonymisation claims to data minimisation is not explicitly covered.

```
{
  "article_number": 11,
  "article_title": "Processing without identification",
  "chapter": "Ch.2 – Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state that the controller shall inform the data subject if it is not in a position to identify them, as required by Article 11(2).",
    "The policy does not mention the conditions under which Articles 15-20 would still apply, even if the data subject cannot be identified, as per Article 11(2).",
    "The policy does not clearly link anonymisation/pseudonymisation claims to data minimisation principles elsewhere in the policy, as guided by the agent."
  ],
  "evidence": [
    "Article 11(1) states that if purposes do not require identification, the controller is not obliged to maintain, acquire, or process additional information to identify the data subject.",
    "Article 11(2) states that if the controller is unable to identify the data subject, they should inform them if possible, and Articles 15-20 do not apply unless the data subject provides identifying information.",
    "Article 4(5) defines pseudonymisation, which is relevant to processing without direct identification."
  ],
}
```

```

    "risk": "medium",
    "needs_human_review": false,
    "notes": "The policy addresses the core concept of Article 11 by allowing processing without
identification when not necessary. However, it lacks specific details on informing data
subjects when identification is not possible and the exceptions to data subject rights in such
scenarios. The agent's guidance on linking anonymisation/pseudonymisation claims to data
minimisation is not explicitly covered.",
    "article_material_used": "text"
}

```

Art. 12 — Transparency & modalities

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 44/100

Risk: medium

Gaps

- Policy does not specify a commitment to respond to data subject requests within a one-month timeframe, nor does it detail provisions for extending this period.
- The policy does not explicitly state that information regarding data subject rights will be provided free of charge, except in cases of manifestly unfounded or excessive requests.

Evidence

- Policy mentions "Your rights with respect to information we hold about you as a controller Right to access Right to rectification Right to erasure Right to restriction of processing Right to data portability Right to object Right to complain" [c23 22964-24164].
- Policy mentions "Data subject requests" [c23 22964-24164].
- Policy mentions "Disclosures in compliance with legal obligations Enforcement of our rights Business Transfers Compliance with this Privacy Policy Notification of changes" [c24 23964-24398].

Notes

The policy acknowledges data subject rights and requests in general terms, but lacks specific details regarding the response timeframe, modalities of response (written, electronic, oral), and the free-of-charge provision as mandated by Article 12. While electronic means are implied by the context of online services, explicit mention of providing information in clear and plain language, and facilitating the exercise of rights is missing. The policy needs to be updated to reflect these requirements.

```

{
  "article_number": 12,
  "article_title": "Transparency & modalities",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "Policy does not specify a commitment to respond to data subject requests within a one-
month timeframe, nor does it detail provisions for extending this period. ",
    "The policy does not explicitly state that information regarding data subject rights will
be provided free of charge, except in cases of manifestly unfounded or excessive requests."
  ],
  "evidence": [
    "Policy mentions \"Your rights with respect to information we hold about you as a
controller Right to access Right to rectification Right to erasure Right to restriction of
processing Right to data portability Right to object Right to complain\" [c23 22964-24164].",
    "Policy mentions \"Data subject requests\" [c23 22964-24164].",
    "Policy mentions \"Disclosures in compliance with legal obligations Enforcement of our
rights Business Transfers Compliance with this Privacy Policy Notification of changes\" [c24
23964-24398].",
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy acknowledges data subject rights and requests in general terms, but
lacks specific details regarding the response timeframe, modalities of response (written,
electronic, oral), and the free-of-charge provision as mandated by Article 12. While electronic
means are implied by the context of online services, explicit mention of providing information
in clear and plain language, and facilitating the exercise of rights is missing. The policy
needs to be updated to reflect these requirements.",
  "article_material_used": "text"
}

```

Art. 13 — Info collected from data subject

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 20/100

Risk: medium

Gaps

- The policy does not explicitly state the contact details of the Data Protection Officer (DPO), where applicable (Article 13(1)(b)).
- The policy does not specify the retention period for personal data or the criteria used to determine it (Article 13(2)(a)).
- The policy does not mention the existence of the right to lodge a complaint with a supervisory authority (Article 13(2)(d)).
- The policy does not clarify whether the provision of personal data is a statutory or contractual requirement, or a requirement necessary to enter into a contract, nor the possible consequences of failure to provide such data (Article 13(2)(e)).
- The policy does not address the existence of automated decision-making, including profiling, and information about the logic involved (Article 13(2)(f)).

Evidence

- The policy mentions that when users sign up for an account, information such as name, contact number, email address, company name, and country is collected for account signup.
- The policy states that users may provide additional information like photo, time zone, and language, but these are not required for signup.
- The policy describes the collection of information when users register for events, subscribe to newsletters, download materials, participate in contests, respond to surveys, or request customer support.
- When purchasing, the policy states that name, contact information, and credit card information (or other payment account information) are collected. It also notes that the cardholder's name, address, expiry date, and last four digits of the credit card number are stored, but not the full card number.
- The policy mentions that for future payments, credit card information may be stored in an encrypted format with payment gateway service providers upon user approval.
- The policy states that personal information may be included in testimonials with user opportunity for review and approval.
- Interactions with sales and customer support professionals (email, telephone, chat) are recorded, analyzed, and used for improving interactions.
- When visiting websites, information collected includes internet protocol address, browser type, language preference, time zone, referring URL, date and time of access, operating system, mobile device manufacturer, and mobile network information.

Notes

While the policy details many types of information collected and the purposes for collection, it lacks specific disclosures required by Article 13 concerning DPO contact, data retention criteria, the right to complain to a supervisory authority, contractual/statutory data provision requirements, and automated decision-making. The policy does mention the identity and contact details of the controller (Zoho, with a contact email for privacy inquiries) and potentially recipients (e.g., Payment Gateway Service Providers). It also touches upon the rights to access and delete testimonials and to request removal of referral information. However, the completeness of the information provided under Article 13 is not met due to the identified gaps.

```
{
  "article_number": 13,
  "article_title": "Info collected from data subject",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state the contact details of the Data Protection Officer (DPO), where applicable (Article 13(1)(b)).",
    "The policy does not specify the retention period for personal data or the criteria used to determine it (Article 13(2)(a)).",
    "The policy does not mention the existence of the right to lodge a complaint with a supervisory authority (Article 13(2)(d)).",
    "The policy does not clarify whether the provision of personal data is a statutory or contractual requirement, or a requirement necessary to enter into a contract, nor the possible consequences of failure to provide such data (Article 13(2)(e)).",
```

"The policy does not address the existence of automated decision-making, including profiling, and information about the logic involved (Article 13(2)(f))."

],

"evidence": [

"The policy mentions that when users sign up for an account, information such as name, contact number, email address, company name, and country is collected for account signup.",

"The policy states that users may provide additional information like photo, time zone, and language, but these are not required for signup.",

"The policy describes the collection of information when users register for events, subscribe to newsletters, download materials, participate in contests, respond to surveys, or request customer support.",

"When purchasing, the policy states that name, contact information, and credit card information (or other payment account information) are collected. It also notes that the cardholder's name, address, expiry date, and last four digits of the credit card number are stored, but not the full card number.",

"The policy mentions that for future payments, credit card information may be stored in an encrypted format with payment gateway service providers upon user approval.",

"The policy states that personal information may be included in testimonials with user opportunity for review and approval.",

"Interactions with sales and customer support professionals (email, telephone, chat) are recorded, analyzed, and used for improving interactions.",

"When visiting websites, information collected includes internet protocol address, browser type, language preference, time zone, referring URL, date and time of access, operating system, mobile device manufacturer, and mobile network information.",

"Temporary and permanent cookies are used to identify users and enhance user experience. Unique identifiers are embedded in downloadable products to track usage.",

"Cookies, beacons, tags, scripts, and similar technologies are used to identify visitors, track website navigation, gather demographic information, understand email campaign effectiveness, and for targeted engagement by tracking website activities. Only first-party cookies are used.",

"First-party Local Storage Objects (LSOs) like HTML5 are used to store content information and preferences.",

"Information about the use of products, services, and mobile applications is collected from application logs and in-house analytics tools, including clicks, scrolls, features accessed, access time and frequency, errors, performance data, storage utilized, user settings, configurations, and devices used, along with their locations.",

"Users can log in using federated authentication service providers (e.g., LinkedIn, Microsoft, Google), which authenticate identity and allow sharing of personal information like name and email address.",

"Information may be provided by referrers through referral programs, including name, email address, and other personal information. Users can request removal of their information."

],

"risk": "medium",

"needs_human_review": false,

"notes": "While the policy details many types of information collected and the purposes for collection, it lacks specific disclosures required by Article 13 concerning DPO contact, data retention criteria, the right to complain to a supervisory authority, contractual/statutory data provision requirements, and automated decision-making. The policy does mention the identity and contact details of the controller (Zoho, with a contact email for privacy inquiries) and potentially recipients (e.g., Payment Gateway Service Providers). It also touches upon the rig

... (truncated)

Art. 14 — Info not obtained from data subject

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 44/100

Risk: low

Gaps

- The policy does not explicitly state the source of the personal data if it was obtained indirectly, nor does it mention whether it came from publicly accessible sources.
- Information regarding the existence of automated decision-making, including profiling, the logic involved, and its envisaged consequences is not provided.

Evidence

- { 'type': 'policy', 'content': "Where personal data have not been obtained from the data subject, the controller shall provide the data subject with the following information:\n (a) the identity and the contact details of the controller and, where applicable, of the controller's representative;\n (b) the contact details of the data protection officer, where applicable;\n (c) the purposes of the processing for which the personal data are intended as well as the legal basis for the processing;\n (d) the categories of personal data concerned;\n (e) the recipients or categories of recipients of the personal data, if any;\n (f) where applicable, that the controller intends to transfer personal data to a recipient in a third country or international organisation and the existence

or absence of an adequacy decision by the Commission, or in the case of transfers referred to in Article 46 or 47, or the second subparagraph of Article 49(1), reference to the appropriate or suitable safeguards and the means to obtain a copy of them or where they have been made available.\n(2) In addition to the information referred to in paragraph 1, the controller shall provide the data subject with the following information necessary to ensure fair and transparent processing in respect of the data subject:\n (a) the period for which the personal data will be stored, or if that is not possible, the criteria used to determine that period;\n (b) where the processing is based on point (f) of Article 6(1), the legitimate interests pursued by the controller or by a third party;\n (c) the existence of the right to request from the controller access to and rectification or erasure of personal data or restriction of processing concerning the data subject and to object to processing as well as the right to data portability;\n (d) where processing is based on point (a) of Article 6(1) or point (a) of Article 9(2), the existence of the right to withdraw consent at any time, without affecting the lawfulness of processing based on consent before its withdrawal;\n (e) the right to lodge a complaint with a supervisory authority;\n (f) from which source the personal data originate, and if applicable, whether it came from publicly accessible sources;\n (g) the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.\n(3) The controller shall provide the information referred to in paragraphs 1 and 2:\n (a) within a reasonable period after obtaining the personal data, but at the latest within one month, having regard to the specific circumstances in which the personal data are processed;\n (b) if the personal data are to be used for communication with the data subject, at the latest at the time of the first communication to that data subject; or\n (c) if a disclosure to another recipient is envisaged, at the latest when the personal data are first disclosed.\n(4) Where the controller intends to further process the personal data for a purpose other than that for which the personal data were obtained, the controller shall provide the data subject prior to that further processing with information on that other purpose and with any relevant further information as referred to in paragraph 2."

- {'type': 'policy', 'content': "You have the right to access (and obtain a copy of, if required) the categories of personal information that we hold about you, including the information's source, purpose and period of processing, and the persons to whom the information is shared"}
- {'type': 'policy', 'content': 'Where we rely on legitimate interests as the legal basis and those legitimate interests are not specified above, we will clearly explain to you what those legitimate interests are at the time that we collect your information.'}
- {'type': 'policy', 'content': 'We may share your personal information with our authorized reselling partners in your region, solely for the purpose of contacting you about products that you have downloaded or services that you have signed up for. We will give you an option to opt out of continuing to work with that partner.'}
- {'type': 'policy', 'content': "When you install or purchase any application developed using Zoho's APIs that is posted on Zoho's online marketplace, your name and email address will be shared with the developer of the application, so they may engage with you directly as the provider of that application or service. Zoho does not control the use of your personal information by the developers, which will be based on their own privacy policies."}

Notes

The policy covers most of Article 14 requirements, including controller and DPO details, purposes and legal basis, categories of data, recipients, data retention periods, and rights of data subjects (access, rectification, erasure, restriction, portability, objection, complaint). It also mentions providing information within a reasonable period. However, it lacks explicit mention of the source of indirectly obtained data and details on automated decision-making/profiling.

```
{
  "article_number": 14,
  "article_title": "Info not obtained from data subject",
  "chapter": "Ch.3 - Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state the source of the personal data if it was obtained indirectly, nor does it mention whether it came from publicly accessible sources.",
    "Information regarding the existence of automated decision-making, including profiling, the logic involved, and its envisaged consequences is not provided."
  ],
  "evidence": [
    {
```

```

    "type": "policy",
    "content": "Where personal data have not been obtained from the data subject, the
controller shall provide the data subject with the following information:\n (a) the identity
and the contact details of the controller and, where applicable, of the controller's
representative;\n (b) the contact details of the data protection officer, where applicable;\n
(c) the purposes of the processing for which the personal data are intended as well as the
legal basis for the processing;\n (d) the categories of personal data concerned;\n (e) the
recipients or categories of recipients of the personal data, if any;\n (f) where applicable,
that the controller intends to transfer personal data to a recipient in a third country or
international organisation and the existence or absence of an adequacy decision by the
Commission, or in the case of transfers referred to in Article 46 or 47, or the second
subparagraph of Article 49(1), reference to the appropriate or suitable safeguards and the
means to obtain a copy of them or where they have been made available.\n(2) In addition to the
information referred to in paragraph 1, the controller shall provide the data subject with the
following information necessary to ensure fair and transparent processing in respect of the
data subject:\n (a) the period for which the personal data will be stored, or if that is not
possible, the criteria used to determine that period;\n (b) where the processing is based on
point (f) of Article 6(1), the legitimate interests pursued by the controller or by a third
party;\n (c) the existence of the right to request from the controller access to and
rectification or erasure of personal data or restriction of processing concerning the data
subject and to object to processing as well as the right to data portability;\n (d) where
processing is based on point (a) of Article 6(1) or point (a) of Article 9(2), the existence of
the right to withdraw consent at any time, without affecting the lawfulness of processing based
on consent before its withdrawal;\n (e) the right to lodge a complaint with a supervisory
authority;\n (f) from which source the personal data originate, and if applicable, whether it
came from publicly accessible sources;\n (g) the existence of automated decision-making,
including profiling, referred to in Article 22(1) and (4) and, at least in those cases,
meaningful information about the logic involved, as well as the significance and the envisaged
consequences of such processing for the data subject.\n(3) The controller shall provide the
information referred to in paragraphs 1 and 2:\n (a) within a reasonable period after
obtaining the personal data, but at the latest within one month, having regard to the specific
circumstances in which the personal data are processed;\n (b) if the personal data are to be
used for communication with the data subject, at the latest at the time of the first
communication to that data subject; or\n (c) if a disclosure to another recipient is envisaged,
at the latest when the personal data are first disclosed.\n(4) Where the controller intends to
further process the personal data for a purpose other than that for which the personal data
were obtained, the controller shall provide the data subject prior to that further processing
with information on that other purpose and with any relevant further information as referred to
in paragraph 2."
  },
  {
    "type": "policy",
    "content": "You have the right to access (and obtain a copy of, if required) the
categories of personal information that we hold about you, including the information's source,
purpose and period of processing, and the persons to whom the information is shared"
  },
  {
    "type": "policy",
    "content": "Where we rely on legitimate interests as the legal basis and those legitimate
interests are not specified above, we will clearly explain to you
... (truncated)

```

Art. 15 — Right of access

Priority: p2 **Chapter:** Ch.3 – Rights of data subjects

Severity: warning **Status:** partial

Score: 44/100

Risk: medium

Gaps

- The policy does not explicitly mention the one-month response timeline for SARs, nor does it detail the process for identity verification of the data subject.
- The policy does not specify what categories of data are provided, only that the 'categories of personal information' can be accessed.

Evidence

- c10 10000-11200: You have the right to access (and obtain a copy, if required) the categories of personal information that we hold about you, including the information's source, purpose and period of processing, and the persons to whom the information is shared.

Notes

The policy states that data subjects have the right to access their personal information and obtain a copy. It also mentions that the source, purpose, period of processing, and recipients of the information will be provided. However, it lacks specifics on the response timeline for SARs, identity verification procedures, and detailed

information on the exact content of the 'copy' provided, which are critical components of Article 15 compliance.

```
{
  "article_number": 15,
  "article_title": "Right of access",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly mention the one-month response timeline for SARs, nor does it detail the process for identity verification of the data subject.",
    "The policy does not specify what categories of data are provided, only that the 'categories of personal information' can be accessed."
  ],
  "evidence": [
    "c10 10000-11200: You have the right to access (and obtain a copy, if required) the categories of personal information that we hold about you, including the information's source, purpose and period of processing, and the persons to whom the information is shared."
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy states that data subjects have the right to access their personal information and obtain a copy. It also mentions that the source, purpose, period of processing, and recipients of the information will be provided. However, it lacks specifics on the response timeline for SARs, identity verification procedures, and detailed information on the exact content of the 'copy' provided, which are critical components of Article 15 compliance.",
  "article_material_used": "text"
}
```

Art. 16 — Right to rectification

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: info Status: pass

Score: 100/100

Risk: low

Evidence

- {policy_chunk_id: 'c10 10000-11200', finding: 'You have the right to update the information we hold about you or to rectify any inaccuracies. Based on the purpose for which we use your information, you can instruct us to add supplemental information about you in our database.'}

Notes

The policy explicitly states the right to rectify inaccuracies. However, it does not explicitly mention the 'without undue delay' condition or equivalent phrasing. It also does not mention the right to have incomplete data completed by means of a supplementary statement.

```
{
  "article_number": 16,
  "article_title": "Right to rectification",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "pass",
  "gaps": [],
  "evidence": [
    {
      "policy_chunk_id": "c10 10000-11200",
      "finding": "You have the right to update the information we hold about you or to rectify any inaccuracies. Based on the purpose for which we use your information, you can instruct us to add supplemental information about you in our database."
    }
  ],
  "risk": "low",
  "needs_human_review": false,
  "notes": "The policy explicitly states the right to rectify inaccuracies. However, it does not explicitly mention the 'without undue delay' condition or equivalent phrasing. It also does not mention the right to have incomplete data completed by means of a supplementary statement.",
  "article_material_used": "text"
}
```

Art. 17 — Right to erasure

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 36/100

Risk: medium

Gaps

- The policy does not explicitly describe the process for handling deletion requests, including timelines for response and confirmation of deletion.
- The policy does not detail any specific grounds for refusing a deletion request, nor the process for informing the data subject of such a refusal.
- The policy does not mention any exceptions to the right to erasure, such as legal obligations or legitimate research purposes as outlined in Article 17(3).

Evidence

- c10 10000-11200: You have the right to request that we delete your personal information in certain circumstances, such as when it is no longer necessary for the purpose for which it was originally collected.

Notes

The policy acknowledges the right to request deletion under certain circumstances (c10), but lacks detail on the procedure, refusal grounds, and exceptions required by Article 17.

```
{
  "article_number": 17,
  "article_title": "Right to erasure",
  "chapter": "Ch.3 - Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly describe the process for handling deletion requests, including timelines for response and confirmation of deletion.",
    "The policy does not detail any specific grounds for refusing a deletion request, nor the process for informing the data subject of such a refusal.",
    "The policy does not mention any exceptions to the right to erasure, such as legal obligations or legitimate research purposes as outlined in Article 17(3).",
  ],
  "evidence": [
    "c10 10000-11200: You have the right to request that we delete your personal information in certain circumstances, such as when it is no longer necessary for the purpose for which it was originally collected."
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy acknowledges the right to request deletion under certain circumstances (c10), but lacks detail on the procedure, refusal grounds, and exceptions required by Article 17.",
  "article_material_used": "text"
}
```

Art. 18 — Right to restriction

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: info Status: pass

Score: 100/100

Risk: low

Evidence

- { 'chunk_id': 'c10 10000-11200', 'content': ': You may also have the right to request to restrict the use of your information in certain circumstances, such as when you have objected to our use of your data but we need to verify whether we have overriding legitimate grounds to use it.' }

Notes

The policy explicitly states the right to request restriction of use of information, aligning with Article 18.

```
{
  "article_number": 18,
  "article_title": "Right to restriction",
  "chapter": "Ch.3 - Rights of data subjects",
  "priority": "p2",
  "status": "pass",
  "gaps": [],
  "evidence": [
    {
      "chunk_id": "c10 10000-11200",
      "content": ": You may also have the right to request to restrict the use of your information in certain circumstances, such as when you have objected to our use of your data but we need to verify whether we have overriding legitimate grounds to use it."
    }
  ],
  "risk": "low",
  "needs_human_review": false,
}
```



```

    "notes": "The policy explicitly states the right to request restriction of use of information,
    aligning with Article 18.",
    "article_material_used": "text"
}

```

Art. 19 — Notification on rectification/erasure

Priority: p3 Chapter: Ch.3 – Rights of data subjects

Severity: critical Status: missing

Score: 0/100

Notes

The policy mentions rectification and deletion of personal information, but does not mention the requirement to notify recipients after these actions.

```

{
  "article_number": 19,
  "article_title": "Notification on rectification/erasure",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy mentions rectification and deletion of personal information, but does
  not mention the requirement to notify recipients after these actions.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 20 — Right to data portability

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 52/100

Risk: medium

Gaps

- The policy does not explicitly mention the right to transmit data to another controller without hindrance, or the direct controller-to-controller transfer right where technically feasible.

Evidence

- c10 10000-11200: You have the right to transfer your information to
- c11 11000-12200: You have the right to transfer your information to a third party in a structured, commonly used and machine-readable format, in circumstances where the information is processed with your consent or by automated means.

Notes

The policy mentions the right to transfer information to a third party in a structured, commonly used, and machine-readable format, which aligns with parts of Article 20. However, it lacks specific mention of the 'without hindrance' clause and the direct controller-to-controller transfer right. The condition 'where the information is processed with your consent or by automated means' is present, which is a condition of Article 20.

```

{
  "article_number": 20,
  "article_title": "Right to data portability",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly mention the right to transmit data to another controller
    without hindrance, or the direct controller-to-controller transfer right where technically
    feasible."
  ],
  "evidence": [
    "c10 10000-11200: You have the right to transfer your information to",
    "c11 11000-12200: You have the right to transfer your information to a third party in a
    structured, commonly used and machine-readable format, in circumstances where the information
    is processed with your consent or by automated means."
  ],
  "risk": "medium",
  "needs_human_review": false,
}

```

```

"notes": "The policy mentions the right to transfer information to a third party in a structured, commonly used, and machine-readable format, which aligns with parts of Article 20. However, it lacks specific mention of the 'without hindrance' clause and the direct controller-to-controller transfer right. The condition 'where the information is processed with your consent or by automated means' is present, which is a condition of Article 20.",
"article_material_used": "text"
}

```

Art. 21 — Right to object

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 44/100

Risk: medium

Gaps

- The policy does not explicitly state that the right to object to direct marketing and profiling is presented clearly and separately from any other information, as required by Article 21(4).
- The policy does not confirm if the right to object can be exercised by automated means using technical specifications, as per Article 21(5).

Evidence

- c7 7000-8200: 'You may opt out of receiving newsletters and other non-essential messages by using the 'unsubscribe' function included in all such messages.'
- c10 10000-11200: 'You have the right to object to the use of your information in certain circumstances, such as the use of your personal information for direct marketing.'
- c11 11000-12200: 'You have the right to object to the use of your information in certain circumstances, such as the use of your personal information for direct marketing.'

Notes

While the policy acknowledges the right to object to direct marketing and provides an opt-out mechanism (unsubscribe function), it lacks specific details on how this right is presented to the user (clear and separate information) and whether automated means of objection are supported, as mandated by Article 21.

```

{
  "article_number": 21,
  "article_title": "Right to object",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state that the right to object to direct marketing and profiling is presented clearly and separately from any other information, as required by Article 21(4).",
    "The policy does not confirm if the right to object can be exercised by automated means using technical specifications, as per Article 21(5).",
  ],
  "evidence": [
    "c7 7000-8200: 'You may opt out of receiving newsletters and other non-essential messages by using the 'unsubscribe' function included in all such messages.'",
    "c10 10000-11200: 'You have the right to object to the use of your information in certain circumstances, such as the use of your personal information for direct marketing.'",
    "c11 11000-12200: 'You have the right to object to the use of your information in certain circumstances, such as the use of your personal information for direct marketing.'",
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "While the policy acknowledges the right to object to direct marketing and provides an opt-out mechanism (unsubscribe function), it lacks specific details on how this right is presented to the user (clear and separate information) and whether automated means of objection are supported, as mandated by Article 21.",
  "article_material_used": "text"
}

```

Art. 22 — Automated decision-making

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 44/100

Risk: high

Gaps

- The policy does not explicitly state whether decisions produced by automated processing, including profiling, that produce legal or similarly significant effects on the data subject are subject to disclosure, human review, or the right to contest. While Article 22(3) mandates these rights when relying on consent or contractual necessity, the policy does not detail how these rights are upheld if automated decision-making is used in other permissible contexts or if it is not based on consent or contract.
- The policy does not provide specific details on the 'suitable measures' implemented to safeguard data subjects' rights and freedoms when automated decision-making is necessary for contract performance or based on explicit consent, as required by Article 22(3).

Evidence

- Policy Chunk [c10 10000-11200] mentions the right to transfer information to a third party in a structured, commonly used and machine-readable format, in circumstances where the information is processed with your consent or by automated means. This indicates an awareness of automated processing but does not fully address Article 22 requirements.
- Policy Chunk [c10 10000-11200] mentions the right to request to restrict the use of your information in certain circumstances, such as when you have objected to our use of your data but we need to verify whether we have overriding legitimate grounds to use it. This is tangentially related to contesting decisions but not specific to automated decision-making.
- Policy Chunk [c11 11000-12200] mentions the right to object to the use of your information in certain circumstances, such as the use of your personal information for direct marketing. This is not directly related to automated decision-making.
- Article 22(1) states that data subjects have the right not to be subject to decisions based solely on automated processing, including profiling, which produce legal effects or similarly significant effects. The provided policy chunks do not contain explicit statements confirming adherence to this right.
- Article 22(3) requires controllers to implement suitable measures to safeguard data subjects' rights and freedoms when decisions are based on contract performance or explicit consent. The provided policy chunks do not detail these specific measures in relation to automated decision-making.

Notes

The policy acknowledges automated processing in the context of data transfer rights but lacks explicit information regarding the right not to be subject to automated decisions, the right to human intervention, and the right to contest such decisions as mandated by GDPR Article 22. Specific 'suitable measures' for safeguarding rights in cases of automated decision-making are not detailed. Further clarification is needed to ensure compliance with Article 22.

```
{
  "article_number": 22,
  "article_title": "Automated decision-making",
  "chapter": "Ch.3 - Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state whether decisions produced by automated processing, including profiling, that produce legal or similarly significant effects on the data subject are subject to disclosure, human review, or the right to contest. While Article 22(3) mandates these rights when relying on consent or contractual necessity, the policy does not detail how these rights are upheld if automated decision-making is used in other permissible contexts or if it is not based on consent or contract.",
    "The policy does not provide specific details on the 'suitable measures' implemented to safeguard data subjects' rights and freedoms when automated decision-making is necessary for contract performance or based on explicit consent, as required by Article 22(3).",
  ],
  "evidence": [
    "Policy Chunk [c10 10000-11200] mentions the right to transfer information to a third party in a structured, commonly used and machine-readable format, in circumstances where the information is processed with your consent or by automated means. This indicates an awareness of automated processing but does not fully address Article 22 requirements.",
    "Policy Chunk [c10 10000-11200] mentions the right to request to restrict the use of your information in certain circumstances, such as when you have objected to our use of your data but we need to verify whether we have overriding legitimate grounds to use it. This is tangentially related to contesting decisions but not specific to automated decision-making.",
    "Policy Chunk [c11 11000-12200] mentions the right to object to the use of your information in certain circumstances, such as the use of your personal information for direct marketing. This is not directly related to automated decision-making.",
    "Article 22(1) states that data subjects have the right not to be subject to decisions based solely on automated processing, including profiling, which produce legal effects or similarly significant effects. The provided policy chunks do not contain explicit statements
```

```

confirming adherence to this right.",
  "Article 22(3) requires controllers to implement suitable measures to safeguard data
subjects' rights and freedoms when decisions are based on contract performance or explicit
consent. The provided policy chunks do not detail these specific measures in relation to
automated decision-making."
],
"risk": "high",
"needs_human_review": false,
"notes": "The policy acknowledges automated processing in the context of data transfer rights
but lacks explicit information regarding the right not to be subject to automated decisions,
the right to human intervention, and the right to contest such decisions as mandated by GDPR
Article 22. Specific 'suitable measures' for safeguarding rights in cases of automated decision-
making are not detailed. Further clarification is needed to ensure compliance with Article 22.",
"article_material_used": "text"
}

```

Art. 24 — Responsibility of the controller

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: warning Status: partial

Score: 36/100

Risk: medium

Gaps

- The policy does not explicitly state that the controller takes into account the nature, scope, context, and purposes of processing as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons when implementing technical and organisational measures. While security certifications (ISO27001, SOC 2 Type II) are mentioned, the direct link to Article 24(1)'s risk-based approach to measure implementation is not clearly articulated.
- The policy mentions implementing appropriate administrative, technical & physical safeguards but does not explicitly detail the review and updating process for these measures as required by Article 24(1).
- While data protection policies are mentioned as being communicated to employees (c15), it is not explicitly stated that these policies are implemented by the controller as referred to in Article 24(2), especially where proportionate to processing activities.

Evidence

- c17: 'At Zoho, we take data security very seriously. That's why we have gotten certified for industry standards such as ISO27001:2013 and SOC 2 Type II.'
- c18: 'We have taken steps to implement appropriate administrative, technical & physical safeguards to prevent unauthorized access, use, modification, disclosure or destruction of the information you entrust to us.'
- c15: 'We communicate our privacy and security guidelines to our employees and strictly enforce privacy safeguards within the Zoho group.'

Notes

The policy demonstrates a commitment to security and has relevant certifications, suggesting an awareness of controller responsibilities. However, it lacks explicit articulation of the review and update mechanism for technical and organisational measures and a clear statement on implementing data protection policies as required by Article 24(1) and (2). The demonstration of compliance through codes of conduct or certification (Article 24(3)) is partially met by the mention of ISO27001 and SOC 2 Type II.

```

{
  "article_number": 24,
  "article_title": "Responsibility of the controller",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state that the controller takes into account the nature,
scope, context, and purposes of processing as well as the risks of varying likelihood and
severity for the rights and freedoms of natural persons when implementing technical and
organisational measures. While security certifications (ISO27001, SOC 2 Type II) are mentioned,
the direct link to Article 24(1)'s risk-based approach to measure implementation is not clearly
articulated.",
    "The policy mentions implementing appropriate administrative, technical & physical
safeguards but does not explicitly detail the review and updating process for these measures as
required by Article 24(1).",
    "While data protection policies are mentioned as being communicated to employees (c15), it
is not explicitly stated that these policies are implemented by the controller as referred to
in Article 24(2), especially where proportionate to processing activities."
  ],

```

```

    "evidence": [
      "c17: 'At Zoho, we take data security very seriously. That's why we have gotten certified for industry standards such as ISO27001:2013 and SOC 2 Type II.'",
      "c18: 'We have taken steps to implement appropriate administrative, technical & physical safeguards to prevent unauthorized access, use, modification, disclosure or destruction of the information you entrust to us.'",
      "c15: 'We communicate our privacy and security guidelines to our employees and strictly enforce privacy safeguards within the Zoho group.'",
    ],
    "risk": "medium",
    "needs_human_review": false,
    "notes": "The policy demonstrates a commitment to security and has relevant certifications, suggesting an awareness of controller responsibilities. However, it lacks explicit articulation of the review and update mechanism for technical and organisational measures and a clear statement on implementing data protection policies as required by Article 24(1) and (2). The demonstration of compliance through codes of conduct or certification (Article 24(3)) is partially met by the mention of ISO27001 and SOC 2 Type II.",
    "article_material_used": "text"
  }

```

Art. 25 — Privacy by design and default

Priority: p3 **Chapter:** Ch.4 – Controller & processor

Severity: critical **Status:** missing

Score: 0/100

Notes

The provided text focuses on data handling, security measures, and third-party integrations, but it does not explicitly mention or describe principles of privacy by design or privacy by default in its operations or policies.

```

{
  "article_number": 25,
  "article_title": "Privacy by design and default",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided text focuses on data handling, security measures, and third-party integrations, but it does not explicitly mention or describe principles of privacy by design or privacy by default in its operations or policies.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 26 — Joint controllers

Priority: p3 **Chapter:** Ch.4 – Controller & processor

Severity: warning **Status:** present (unverified)

Score: 70/100

Notes

The policy defines 'controller' as someone who 'alone or jointly with others' determines the purposes and means of processing, which directly addresses the concept of joint controllership mentioned in Article 26.

```

{
  "article_number": 26,
  "article_title": "Joint controllers",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": true,
  "implementation_unverified": true,
  "needs_human_review": true,
  "evidence": "('controller' means the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law;)",
  "notes": "The policy defines 'controller' as someone who 'alone or jointly with others' determines the purposes and means of processing, which directly addresses the concept of joint controllership mentioned in Article 26.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 27 — Representatives (non-EU)

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

Notes

The provided text only includes definitions and does not address the requirements for non-EU representatives mandated by Article 27 of the GDPR.

```
{
  "article_number": 27,
  "article_title": "Representatives (non-EU)",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided text only includes definitions and does not address the requirements
for non-EU representatives mandated by Article 27 of the GDPR.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 28 — Processor / DPA

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: warning Status: partial

Score: 20/100

Risk: medium

Gaps

- The policy does not explicitly state that the processor must obtain prior specific or general written authorization from the controller before engaging a sub-processor, nor does it detail the process for informing the controller of intended changes to sub-processors and providing an opportunity to object.
- The policy does not explicitly detail the audit rights of the controller, including the provision of all necessary information to demonstrate compliance and allowing for/contributing to audits and inspections.
- While the policy mentions assisting the controller with data subject rights requests, it lacks specifics on the nature and extent of this assistance and how it aligns with Article 28(3)(e) and (f).
- The policy does not explicitly state that the processor will immediately inform the controller if an instruction infringes data protection law.
- The policy does not explicitly confirm that the processor will make available to the controller all information necessary to demonstrate compliance with data protection obligations and allow for audits, including inspections.

Evidence

- All Zoho group entities listed here have access to the information covered in Part I. We do not sell any personal information. We share your information only in the ways that are described in this
- Employees and independent contractors of all Zoho group entities have access to the information covered in Part I on a need-to-know basis. We require all employees and independent contractors of Zoho group entities to follow this
- We may need to share your personal information and aggregated or de-identified information with third-party service providers that we engage, such as marketing and advertising partners, event organizers, web analytics providers and payment processors. These service providers are authorized to use your personal information only as necessary to provide these services to us.
- When you register a domain through Zoho from domain name registrars, we share your name and contact information such as your physical address, email address and phone number with them as per the ICANN domain registration rules.
- We may share your personal information with our authorized reselling partners in your region, solely for the purpose of contacting you about products that you have downloaded or services that you have signed up for. We will give you an option to opt out of continuing to work with that partner.

- When you install or purchase any application developed using Zoho's APIs that is posted on Zoho's online marketplace, your name and email address will be shared with the developer of the application, so they may engage with you directly as the provider of that application or service. Zoho does not control the use of your personal information by the developers, which will be based on their own privacy policies.
- Other scenarios in which we may share the same information covered under Parts I and II are described in Part III. If you are in the European Economic Area (EEA), you have the following rights with respect to information that Zoho holds about you. Zoho undertakes to provide you the same rights no matter where you choose to live.
- You have the right to access (and obtain a copy of, if required) the categories of personal information that we hold about you, including the information's source, purpose and period of processing, and the persons to whom the information is shared

Notes

The policy provides some general statements about data sharing and third-party service providers but lacks explicit clauses addressing all requirements of Article 28 concerning sub-processors, audit rights, and the processor's obligation to inform the controller of infringing instructions. While the policy outlines data subject rights and the right to request deletion, it doesn't specifically tie these obligations to the processor's role under Article 28(3)(e) or (f).

```
{
  "article_number": 28,
  "article_title": "Processor / DPA",
  "chapter": "Ch.4 - Controller & processor",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state that the processor must obtain prior specific or general written authorization from the controller before engaging a sub-processor, nor does it detail the process for informing the controller of intended changes to sub-processors and providing an opportunity to object.",
    "The policy does not explicitly detail the audit rights of the controller, including the provision of all necessary information to demonstrate compliance and allowing for/contributing to audits and inspections.",
    "While the policy mentions assisting the controller with data subject rights requests, it lacks specifics on the nature and extent of this assistance and how it aligns with Article 28(3)(e) and (f).",
    "The policy does not explicitly state that the processor will immediately inform the controller if an instruction infringes data protection law.",
    "The policy does not explicitly confirm that the processor will make available to the controller all information necessary to demonstrate compliance with data protection obligations and allow for audits, including inspections."
  ],
  "evidence": [
    "All Zoho group entities listed here have access to the information covered in Part I. We do not sell any personal information. We share your information only in the ways that are described in this",
    "Employees and independent contractors of all Zoho group entities have access to the information covered in Part I on a need-to-know basis. We require all employees and independent contractors of Zoho group entities to follow this",
    "We may need to share your personal information and aggregated or de-identified information with third-party service providers that we engage, such as marketing and advertising partners, event organizers, web analytics providers and payment processors. These service providers are authorized to use your personal information only as necessary to provide these services to us.",
    "When you register a domain through Zoho from domain name registrars, we share your name and contact information such as your physical address, email address and phone number with them as per the ICANN domain registration rules.",
    "We may share your personal information with our authorized reselling partners in your region, solely for the purpose of contacting you about products that you have downloaded or services that you have signed up for. We will give you an option to opt out of continuing to work with that partner.",
    "When you install or purchase any application developed using Zoho's APIs that is posted on Zoho's online marketplace, your name and email address will be shared with the developer of the application, so they may engage with you directly as the provider of that application or service. Zoho does not control the use of your personal information by the developers, which will be based on their own privacy policies.",
    "Other scenarios in which we may share the same information covered under Parts I and II are described in Part III. If you are in the European Economic Area (EEA), you have the following rights with respect to information that Zoho holds about you. Zoho undertakes to provide you the same rights no matter where you choose to live.",
    "You have the right to access (and obtain a copy of, if required) the categories of personal information that we hold about you, including the information's source, purpose and period of processing, and the persons to whom the information is shared",
    "You have the right to update the information we hold about you or to rectify any inaccuracies. Based on the purpose for which we use your information, you can instruct us to add supplemental information about you in our database."
  ]
}
```

"You have the right to request that we delete your personal information in certain circumstances, such as when it is no longer necessary for the purpose for which it was originally collected.",

"You may also have the right to request to restrict the use of your information in certain circumstances, such as when you have objected to our use of your data but we need to verify whether we have overriding legitimate grounds to use it.",

"You have the right to transfer your information to a third party in a structured, commonly used and machine-readable format, in circumstances
... (truncated)

Art. 29 — Processing under authority

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: critical Status: fail

Score: 0/100

Risk: critical

Gaps

- The policy does not explicitly state that the processor and any person acting under the authority of the controller or processor shall not process personal data except on instructions from the controller, unless required by Union or Member State law. This is a direct mapping of Article 29.

Evidence

- The provided policy chunks do not contain specific clauses that directly address the requirements of GDPR Article 29 regarding processing under the authority of the controller or processor.

Notes

Article 29 is a fundamental requirement for data processing. The absence of this clause indicates a significant gap in compliance, as it allows for processing without explicit instructions, which could lead to unauthorized or non-compliant data handling.

```
{
  "article_number": 29,
  "article_title": "Processing under authority",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not explicitly state that the processor and any person acting under the authority of the controller or processor shall not process personal data except on instructions from the controller, unless required by Union or Member State law. This is a direct mapping of Article 29."
  ],
  "evidence": [
    "The provided policy chunks do not contain specific clauses that directly address the requirements of GDPR Article 29 regarding processing under the authority of the controller or processor."
  ],
  "risk": "critical",
  "needs_human_review": false,
  "notes": "Article 29 is a fundamental requirement for data processing. The absence of this clause indicates a significant gap in compliance, as it allows for processing without explicit instructions, which could lead to unauthorized or non-compliant data handling.",
  "article_material_used": "text"
}
```

Art. 30 — Records of processing (ROPA)

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: warning Status: partial

Score: 20/100

Risk: medium

Gaps

- The policy does not explicitly state the 'purposes of the processing' (Article 30(1)(b)).
- The policy does not explicitly mention 'categories of recipients' (Article 30(1)(d)).
- The policy does not explicitly mention 'retention periods' or 'time limits for erasure' (Article 30(1)(f)).
- The policy does not explicitly mention 'technical and organisational security measures' (Article 30(1)(g)).
- The policy does not explicitly state the 'categories of data subjects' (Article 30(1)(c)).

Evidence

- Article 30(1) of GDPR mandates controllers to maintain records of processing activities.
- The provided policy chunks discuss data sharing with third-party service providers (c8, c9) and Zoho group entities (c7, c8), implying recipients, but not in a structured ROPA format.
- The policy mentions rights related to accessing, updating, deleting, and restricting personal information (c10), which indirectly relates to data handling but not a formal ROPA.
- The policy mentions that Zoho shares information with domain name registrars as per ICANN rules (c9) and with developers of applications from Zoho's marketplace (c9).
- The policy mentions employees and contractors have access on a need-to-know basis (c8).

Notes

The policy does not contain a specific ROPA document. While some elements like data sharing and access controls are mentioned, they are not presented in the structured format required by Article 30. The 'exceptions' for smaller enterprises (Article 30(5)) are not mentioned, but the provided text doesn't suggest the entity is a small enterprise.

```
{
  "article_number": 30,
  "article_title": "Records of processing (ROPA)",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state the 'purposes of the processing' (Article 30(1)(b)).",
    "The policy does not explicitly mention 'categories of recipients' (Article 30(1)(d)).",
    "The policy does not explicitly mention 'retention periods' or 'time limits for erasure' (Article 30(1)(f)).",
    "The policy does not explicitly mention 'technical and organisational security measures' (Article 30(1)(g)).",
    "The policy does not explicitly state the 'categories of data subjects' (Article 30(1)(c))."
  ],
  "evidence": [
    "Article 30(1) of GDPR mandates controllers to maintain records of processing activities.",
    "The provided policy chunks discuss data sharing with third-party service providers (c8, c9) and Zoho group entities (c7, c8), implying recipients, but not in a structured ROPA format.",
    "The policy mentions rights related to accessing, updating, deleting, and restricting personal information (c10), which indirectly relates to data handling but not a formal ROPA.",
    "The policy mentions that Zoho shares information with domain name registrars as per ICANN rules (c9) and with developers of applications from Zoho's marketplace (c9).",
    "The policy mentions employees and contractors have access on a need-to-know basis (c8).",
    "The policy does not contain a specific ROPA document. While some elements like data sharing and access controls are mentioned, they are not presented in the structured format required by Article 30. The 'exceptions' for smaller enterprises (Article 30(5)) are not mentioned, but the provided text doesn't suggest the entity is a small enterprise."
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy does not contain a specific ROPA document. While some elements like data sharing and access controls are mentioned, they are not presented in the structured format required by Article 30. The 'exceptions' for smaller enterprises (Article 30(5)) are not mentioned, but the provided text doesn't suggest the entity is a small enterprise.",
  "article_material_used": "text"
}
```

Art. 32 — Security of processing

Priority: p3 **Chapter:** Ch.4 – Controller & processor

Severity: critical **Status:** missing

Score: 0/100

```
{
  "article_number": 32,
  "article_title": "Security of processing",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": null,
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 33 — Breach notification to SA

Priority: p3 **Chapter:** Ch.4 – Controller & processor

Severity: critical Status: missing
Score: 0/100
Notes

The provided text focuses on data subject rights, data sharing, and data processing purposes. It does not contain any information regarding breach notification procedures to a supervisory authority within 72 hours or the contact details of a Data Protection Officer (DPO) for such purposes.

```
{
  "article_number": 33,
  "article_title": "Breach notification to SA",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided text focuses on data subject rights, data sharing, and data processing
purposes. It does not contain any information regarding breach notification procedures to a
supervisory authority within 72 hours or the contact details of a Data Protection Officer (DPO)
for such purposes.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 34 — Breach communication to data subject

Priority: p3 Chapter: Ch.4 – Controller & processor
Severity: critical Status: missing
Score: 0/100
Notes

The provided policy excerpts do not contain any information related to breach communication to data subjects or procedures for handling high-risk breaches. The text focuses on data subject rights, data sharing, and general data processing principles.

```
{
  "article_number": 34,
  "article_title": "Breach communication to data subject",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided policy excerpts do not contain any information related to breach
communication to data subjects or procedures for handling high-risk breaches. The text focuses
on data subject rights, data sharing, and general data processing principles.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 35 — DPIA

Priority: p3 Chapter: Ch.4 – Controller & processor
Severity: critical Status: missing
Score: 0/100
Notes

The provided text discusses data subject rights, data sharing, and data retention periods. It does not mention or address Data Protection Impact Assessments (DPIAs) or the requirement for them, which is the core topic of GDPR Article 35.

```
{
  "article_number": 35,
  "article_title": "DPIA",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided text discusses data subject rights, data sharing, and data retention
```

```

periods. It does not mention or address Data Protection Impact Assessments (DPIAs) or the
requirement for them, which is the core topic of GDPR Article 35.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 37 — DPO designation

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: info Status: pass

Score: 100/100

Risk: low

Evidence

- { 'policy_chunk_id': 'c18 17964-19164', 'chunk_content': 'We have appointed a Data Protection Officer to oversee our management of your personal information in accordance with this' }

Notes

The policy states that a Data Protection Officer has been appointed. The policy does not explicitly state if this is to meet the criteria outlined in Article 37 (a), (b), or (c), but it is implied that a DPO is in place.

```

{
  "article_number": 37,
  "article_title": "DPO designation",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "pass",
  "gaps": [],
  "evidence": [
    {
      "policy_chunk_id": "c18 17964-19164",
      "chunk_content": "We have appointed a Data Protection Officer to oversee our management
of your personal information in accordance with this"
    }
  ],
  "risk": "low",
  "needs_human_review": false,
  "notes": "The policy states that a Data Protection Officer has been appointed. The policy
does not explicitly state if this is to meet the criteria outlined in Article 37 (a), (b), or (
c), but it is implied that a DPO is in place.",
  "article_material_used": "text"
}

```

Art. 38 — DPO position

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: warning Status: present (unverified)

Score: 70/100

Notes

The policy mentions the appointment of a Data Protection Officer. However, it does not mention their independence or reporting lines, which requires human verification.

```

{
  "article_number": 38,
  "article_title": "DPO position",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": true,
  "implementation_unverified": true,
  "needs_human_review": true,
  "evidence": "We have appointed a Data Protection Officer to oversee our management of your
personal information in accordance with this",
  "notes": "The policy mentions the appointment of a Data Protection Officer. However, it does
not mention their independence or reporting lines, which requires human verification.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 39 — DPO tasks

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: warning Status: partial

Score: 28/100

Risk: medium

Gaps

- The policy does not explicitly state that the DPO's mandate includes monitoring compliance with 'other Union or Member State data protection provisions' or with 'policies of the controller or processor in relation to the protection of personal data, including the assignment of responsibilities, awareness-raising and training of staff involved in processing operations, and the related audits'.
- The policy does not explicitly mention the DPO's task to 'provide advice where requested as regards the data protection impact assessment and monitor its performance pursuant to Article 35'.
- The policy does not explicitly state that the DPO's mandate includes cooperating with the supervisory authority.
- The policy does not explicitly state that the DPO acts as a contact point for the supervisory authority on issues relating to processing, including prior consultation, or when consulting on other matters.

Evidence

- {policy_chunk_id: 'c18', 'snippet': 'We have appointed a Data Protection Officer to oversee our management of your personal information in accordance with this'}

Notes

The policy mentions the appointment of a Data Protection Officer to oversee the management of personal information but does not detail the specific tasks as required by Article 39 of the GDPR. Key tasks such as advising on data protection obligations, monitoring compliance, involvement in DPIAs, and cooperation with supervisory authorities are not explicitly covered in the provided policy chunks.

```
{
  "article_number": 39,
  "article_title": "DPO tasks",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state that the DPO's mandate includes monitoring compliance with 'other Union or Member State data protection provisions' or with 'policies of the controller or processor in relation to the protection of personal data, including the assignment of responsibilities, awareness-raising and training of staff involved in processing operations, and the related audits'.",
    "The policy does not explicitly mention the DPO's task to 'provide advice where requested as regards the data protection impact assessment and monitor its performance pursuant to Article 35'.",
    "The policy does not explicitly state that the DPO's mandate includes cooperating with the supervisory authority.",
    "The policy does not explicitly state that the DPO acts as a contact point for the supervisory authority on issues relating to processing, including prior consultation, or when consulting on other matters."
  ],
  "evidence": [
    {
      "policy_chunk_id": "c18",
      "snippet": "We have appointed a Data Protection Officer to oversee our management of your personal information in accordance with this"
    }
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy mentions the appointment of a Data Protection Officer to oversee the management of personal information but does not detail the specific tasks as required by Article 39 of the GDPR. Key tasks such as advising on data protection obligations, monitoring compliance, involvement in DPIAs, and cooperation with supervisory authorities are not explicitly covered in the provided policy chunks.",
  "article_material_used": "text"
}
```

Art. 40 — Codes of conduct

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

Notes

The provided text focuses on data handling, disclosures, user rights, and general privacy policy elements. It does not contain any mention of 'codes of conduct' or adherence claims to such codes as described in GDPR Article 40.

```
{
  "article_number": 40,
  "article_title": "Codes of conduct",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided text focuses on data handling, disclosures, user rights, and general privacy policy elements. It does not contain any mention of 'codes of conduct' or adherence claims to such codes as described in GDPR Article 40.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 42 — Certification

Priority: p3 Chapter: Ch.4 – Controller & processor
Severity: critical Status: missing
Score: 0/100
Notes

The provided text is an excerpt of GDPR Article 4 definitions. It does not contain any information related to Article 42 on certification.

```
{
  "article_number": 42,
  "article_title": "Certification",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": "The provided text only contains definitions for GDPR articles, not the substantive articles themselves. Therefore, it does not address Article 42 on certification.",
  "notes": "The provided text is an excerpt of GDPR Article 4 definitions. It does not contain any information related to Article 42 on certification.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 44 — General principle for transfers

Priority: p2 Chapter: Ch.5 – Transfers to third countries
Severity: critical Status: fail
Score: 0/100
Risk: critical
Gaps

- The policy chunks provided do not contain any information regarding the mechanisms or safeguards used for international transfers of personal data, which is a core requirement of GDPR Article 44.

Notes

Article 44 requires that any transfer of personal data to a third country or international organisation must comply with Chapter V of the GDPR, ensuring the level of protection for data subjects is not undermined. The provided policy chunks do not address any of these requirements or safeguards for international data transfers.

```
{
  "article_number": 44,
  "article_title": "General principle for transfers",
  "chapter": "Ch.5 – Transfers to third countries",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy chunks provided do not contain any information regarding the mechanisms or safeguards used for international transfers of personal data, which is a core requirement of GDPR Article 44."
  ],
}
```

```

    "evidence": [],
    "risk": "critical",
    "needs_human_review": false,
    "notes": "Article 44 requires that any transfer of personal data to a third country or international organisation must comply with Chapter V of the GDPR, ensuring the level of protection for data subjects is not undermined. The provided policy chunks do not address any of these requirements or safeguards for international data transfers.",
    "article_material_used": "text"
  }

```

Art. 45 — Adequacy decision transfers

Priority: p2 Chapter: Ch.5 – Transfers to third countries

Severity: critical Status: fail

Score: 0/100

Risk: high

Gaps

- The provided policy chunks do not contain any explicit mention of adequacy decisions or the Commission's assessment of third countries for ensuring an adequate level of protection as required by Article 45. There is no information on transfers to third countries or international organizations.

Notes

The policy text does not address Article 45 requirements regarding adequacy decisions for international data transfers. This is a significant gap.

```

{
  "article_number": 45,
  "article_title": "Adequacy decision transfers",
  "chapter": "Ch.5 – Transfers to third countries",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The provided policy chunks do not contain any explicit mention of adequacy decisions or the Commission's assessment of third countries for ensuring an adequate level of protection as required by Article 45. There is no information on transfers to third countries or international organizations."
  ],
  "evidence": [],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The policy text does not address Article 45 requirements regarding adequacy decisions for international data transfers. This is a significant gap.",
  "article_material_used": "text"
}

```

Art. 46 — Transfers with safeguards

Priority: p3 Chapter: Ch.5 – Transfers to third countries

Severity: critical Status: missing

Score: 0/100

Notes

The provided text discusses data transfer and sharing with third parties, and mentions rights related to data transfer, but it does not explicitly mention or address safeguards for international data transfers such as SCCs or BCRs, which are the core of Article 46.

```

{
  "article_number": 46,
  "article_title": "Transfers with safeguards",
  "chapter": "Ch.5 – Transfers to third countries",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided text discusses data transfer and sharing with third parties, and mentions rights related to data transfer, but it does not explicitly mention or address safeguards for international data transfers such as SCCs or BCRs, which are the core of Article 46.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 47 — Binding corporate rules

Priority: p3 Chapter: Ch.5 – Transfers to third countries

Severity: critical Status: missing

Score: 0/100

Notes

The provided text discusses data protection in general terms, including data collection, sharing, and user rights. However, it does not contain any specific mention or discussion of Binding Corporate Rules (BCRs) as required by GDPR Article 47.

```
{
  "article_number": 47,
  "article_title": "Binding corporate rules",
  "chapter": "Ch.5 – Transfers to third countries",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided text discusses data protection in general terms, including data collection, sharing, and user rights. However, it does not contain any specific mention or discussion of Binding Corporate Rules (BCRs) as required by GDPR Article 47.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 77 — Right to lodge a complaint

Priority: p2 Chapter: Ch.8 – Remedies, liability & penalties

Severity: info Status: pass

Score: 100/100

Risk: low

Evidence

- { 'policy_chunk_id': 'c11 11000-12200', 'snippet': 'You have the right to complain to the appropriate supervisory authority if you have any grievance against the way we collect, use or share your information.' }

Notes

The policy explicitly informs data subjects of their right to complain to the appropriate supervisory authority if they have any grievance against the way their information is collected, used, or shared.

```
{
  "article_number": 77,
  "article_title": "Right to lodge a complaint",
  "chapter": "Ch.8 – Remedies, liability & penalties",
  "priority": "p2",
  "status": "pass",
  "gaps": [],
  "evidence": [
    {
      "policy_chunk_id": "c11 11000-12200",
      "snippet": "You have the right to complain to the appropriate supervisory authority if you have any grievance against the way we collect, use or share your information."
    }
  ],
  "risk": "low",
  "needs_human_review": false,
  "notes": "The policy explicitly informs data subjects of their right to complain to the appropriate supervisory authority if they have any grievance against the way their information is collected, used, or shared.",
  "article_material_used": "text"
}
```

Art. 85 — Freedom of expression

Priority: p4 Chapter: Ch.9 – Specific processing situations

Severity: warning Status: triggered (HIL)

Notes

The policy text does not explicitly mention exemptions for journalism, academic, or artistic expression. However, Article 85 is a general GDPR provision that needs to be considered when such claims are made.

Therefore, any claim related to these exceptions should be flagged for human review.

```
{
  "article_number": 85,
  "article_title": "Freedom of expression",
  "chapter": "Ch.9 – Specific processing situations",
  "priority": "p4",
  "p4_triggered": true,
  "needs_human_review": true,
  "evidence": "GDPR Article 85 states that processing of personal data for journalistic purposes or the purposes of academic or artistic expression should be exempt from certain GDPR provisions when necessary to reconcile the right to privacy with freedom of expression and information. The conditional scenario asks to auto-detect journalism/academic/artistic derogation claims and always route to human because legitimacy cannot be auto-verified.",
  "what_to_review": [
    "Is the claimed purpose for data processing journalism, academic research, or artistic expression?",
    "Does the scope of data processing align with the claimed purpose and the principle of data minimization?",
    "Are there any safeguards in place to protect individual privacy while pursuing these expressive purposes?",
    "Is the data processing strictly necessary for the claimed purpose, and are there less intrusive means available?"
  ],
  "notes": "The policy text does not explicitly mention exemptions for journalism, academic, or artistic expression. However, Article 85 is a general GDPR provision that needs to be considered when such claims are made. Therefore, any claim related to these exceptions should be flagged for human review.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 88 — Employment context

Priority: p2 Chapter: Ch.9 – Specific processing situations

Severity: critical Status: fail

Score: 0/100

Risk: high

Gaps

- The policy does not explicitly address the processing of employee personal data for recruitment, performance of the employment contract, management, planning and organisation of work, equality and diversity, health and safety, protection of property, or enjoyment of employment rights and benefits.
- There is no specific mention of rules to ensure the protection of employee rights and freedoms in the employment context.
- The policy does not detail suitable and specific measures to safeguard employees' human dignity, legitimate interests, and fundamental rights, particularly concerning transparency, data transfers within the group, or workplace monitoring systems.
- Information regarding the termination of the employment relationship and associated data processing is absent.

Evidence

- c14: Mentions using customer data for invoicing and email marketing, and sharing service data with group entities and third parties for error resolution and verification. No specific employee data context.
- c15: Discusses sharing service data with 'employees' for error resolution and verification, with access restrictions, logging, and auditing. Also mentions collaboration features showing user profile information. No explicit employee privacy context.
- c16: Mentions data retention for user accounts and eventual deletion. No employee context.
- c17: Discusses data security certifications and safeguards. No employee context.
- c18: Details data security measures, sharing within the Zoho Group with cross-border transfer clauses, and consent for processing. No employee context.
- c19: References cross-border data transfers within the Zoho Group based on EU Commission's Model Contractual Clauses. No employee context.

Notes

The provided policy chunks focus heavily on customer data processing, third-party integrations, and general data security within Zoho's services. There is a significant lack of specific provisions addressing the unique

aspects of employee personal data processing as outlined in GDPR Article 88, covering recruitment, employment contract performance, management, workplace monitoring, and termination. The mention of 'employees' in c14 and c15 refers to individuals accessing service data for technical purposes rather than the employer-employee relationship governed by Article 88.

```
{
  "article_number": 88,
  "article_title": "Employment context",
  "chapter": "Ch.9 - Specific processing situations",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not explicitly address the processing of employee personal data for recruitment, performance of the employment contract, management, planning and organisation of work, equality and diversity, health and safety, protection of property, or enjoyment of employment rights and benefits.",
    "There is no specific mention of rules to ensure the protection of employee rights and freedoms in the employment context.",
    "The policy does not detail suitable and specific measures to safeguard employees' human dignity, legitimate interests, and fundamental rights, particularly concerning transparency, data transfers within the group, or workplace monitoring systems.",
    "Information regarding the termination of the employment relationship and associated data processing is absent."
  ],
  "evidence": [
    "c14: Mentions using customer data for invoicing and email marketing, and sharing service data with group entities and third parties for error resolution and verification. No specific employee data context.",
    "c15: Discusses sharing service data with 'employees' for error resolution and verification, with access restrictions, logging, and auditing. Also mentions collaboration features showing user profile information. No explicit employee privacy context.",
    "c16: Mentions data retention for user accounts and eventual deletion. No employee context.",
    "c17: Discusses data security certifications and safeguards. No employee context.",
    "c18: Details data security measures, sharing within the Zoho Group with cross-border transfer clauses, and consent for processing. No employee context.",
    "c19: References cross-border data transfers within the Zoho Group based on EU Commission's Model Contractual Clauses. No employee context."
  ],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The provided policy chunks focus heavily on customer data processing, third-party integrations, and general data security within Zoho's services. There is a significant lack of specific provisions addressing the unique aspects of employee personal data processing as outlined in GDPR Article 88, covering recruitment, employment contract performance, management, workplace monitoring, and termination. The mention of 'employees' in c14 and c15 refers to individuals accessing service data for technical purposes rather than the employer-employee relationship governed by Article 88.",
  "article_material_used": "text"
}
```

Appendix — human review queue

```
[
  {
    "kind": "p3_verify",
    "article_number": 8,
    "article_title": "Child's consent",
    "policy_present": true,
    "implementation_unverified": true,
    "evidence": "Our products and services are not directed to individuals under 16. Zoho does not knowingly collect personal information from children who are under 16 years of age. If we become aware that a child under 16 has provided us with personal information, we will take steps to delete such information. If you believe that a child under 16 years has provided personal information to us, please write to privacy@zohocorp.com with the details, and we will take the necessary steps to delete the information we hold about that child.",
    "notes": "The policy explicitly states that the products and services are not directed at individuals under 16 and that Zoho does not knowingly collect personal information from children under 16. It also outlines the procedure for handling such information if it is discovered."
  },
  {
    "kind": "p3_verify",
    "article_number": 10,
    "article_title": "Criminal convictions data",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": null
  },
  {
    "kind": "p3_verify",
    "article_number": 19,
    "article_title": "Notification on rectification/erasure",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The policy mentions rectification and deletion of personal information, but does not mention the requirement to notify recipients after these actions."
  },
  {
    "kind": "p3_verify",
    "article_number": 25,
    "article_title": "Privacy by design and default",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text focuses on data handling, security measures, and third-party integrations, but it does not explicitly mention or describe principles of privacy by design or privacy by default in its operations or policies."
  },
  {
    "kind": "p3_verify",
    "article_number": 26,
    "article_title": "Joint controllers",
    "policy_present": true,
    "implementation_unverified": true,
    "evidence": "('controller' means the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law;)",
    "notes": "The policy defines 'controller' as someone who 'alone or jointly with others' determines the purposes and means of processing, which directly addresses the concept of joint controllership mentioned in Article 26."
  },
  {
    "kind": "p3_verify",
    "article_number": 27,
    "article_title": "Representatives (non-EU)",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text only includes definitions and does not address the requirements for non-EU representatives mandated by Article 27 of the GDPR."
  },
  {
    "kind": "p3_verify",
    "article_number": 32,
    "article_title": "Security of processing",
    "policy_present": false,
    "implementation_unverified": false,

```

```

    "evidence": [],
    "notes": null
  },
  {
    "kind": "p3_verify",
    "article_number": 33,
    "article_title": "Breach notification to SA",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text focuses on data subject rights, data sharing, and data processing purposes. It does not contain any information regarding breach notification procedures to a supervisory authority within 72 hours or the contact details of a Data Protection Officer (DPO) for such purposes."
  },
  {
    "kind": "p3_verify",
    "article_number": 34,
    "article_title": "Breach communication to data subject",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided policy excerpts do not contain any information related to breach communication to data subjects or procedures for handling high-risk breaches. The text focuses on data subject rights, data sharing, and general data processing principles."
  },
  {
    "kind": "p3_verify",
    "article_number": 35,
    "article_title": "DPIA",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text discusses data subject rights, data sharing, and data retention periods. It does not mention or address Data Protection Impact Assessments (DPIAs) or the requirement for them, which is the core topic of GDPR Article 35."
  },
  {
    "kind": "p3_verify",
    "article_number": 38,
    "article_title": "DPO position",
    "policy_present": true,
    "implementation_unverified": true,
    "evidence": "We have appointed a Data Protection Officer to oversee our management of your personal information in accordance with this",
    "notes": "The policy mentions the appointment of a Data Protection Officer. However, it does not mention their independence or reporting lines, which requires human verification."
  },
  {
    "kind": "p3_verify",
    "article_number": 40,
    "article_title": "Codes of conduct",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text focuses on data handling, disclosures, user rights, and general privacy policy elements. It does not contain any mention of 'codes of conduct' or adherence claims to such codes as described in GDPR Article 40."
  },
  {
    "kind": "p3_verify",
    "article_number": 42,
    "article_title": "Certification",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": "The provided text only contains definitions for GDPR articles, not the substantive articles themselves. Therefore, it does not address Article 42 on certification.",
    "notes": "The provided text is an excerpt of GDPR Article 4 definitions. It does not contain any information related to Article 42 on certification."
  },
  {
    "kind": "p3_verify",
    "article_number": 46,
    "article_title": "Transfers with safeguards",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text discusses data transfer and sharing with third parties, and mentions rights related to data transfer, but it does not explicitly mention or address safeguards for international data transfers such as SCCs or BCRs, which are the core of Article 46."
  },
  {
    "kind": "p3_verify",
    "article_number": 46,
    "article_title": "Transfers with safeguards",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text discusses data transfer and sharing with third parties, and mentions rights related to data transfer, but it does not explicitly mention or address safeguards for international data transfers such as SCCs or BCRs, which are the core of Article 46."
  }
]

```

```

    "kind": "p3_verify",
    "article_number": 47,
    "article_title": "Binding corporate rules",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text discusses data protection in general terms, including data
collection, sharing, and user rights. However, it does not contain any specific mention or
discussion of Binding Corporate Rules (BCRs) as required by GDPR Article 47."
  },
  {
    "kind": "p4_conditional",
    "article_number": 85,
    "article_title": "Freedom of expression",
    "what_to_review": [
      "Is the claimed purpose for data processing journalism, academic research, or artistic
expression?",
      "Does the scope of data processing align with the claimed purpose and the principle of
data minimization?",
      "Are there any safeguards in place to protect individual privacy while pursuing these
expressive purposes?",
      "Is the data processing strictly necessary for the claimed purpose, and are there less
intrusive means available?"
    ],
    "evidence": "GDPR Article 85 states that processing of personal data for journalistic
purposes or the purposes of academic or artistic expression should be exempt from certain GDPR
provisions when necessary to reconcile the right to privacy with freedom of expression and
information. The conditional scenario asks to auto-detect journalism/academic/artistic
derogation claims and always route to human because legitimacy cannot be auto-verified.",
    "notes": "The policy text does not explicitly mention exemptions for journalism, academic,
or artistic expression. However, Article 85 is a general GDPR provision that needs to be
considered when such claims are made. Therefore, any claim related to these exceptions should
be flagged for human review."
  }
]

```